

Enumeracion de NFS

Objetivos de aprendizaje

Identificar la superficie, explicar la causa, diseñar una confirmación mínima, interpretar evidencia y proponer una mitigación causal.

Prerrequisitos

Flujo source-transformación-validación-sink, parsers, permisos y metodología de hipótesis. Revisa los prerrequisitos declarados en los metadatos.

Fundamentos técnicos

NFS (puerto 2049) comparte directorios del servidor para que otras maquinas los monten como si fueran locales. Antes de montar nada, puedes preguntarle al servidor QUE exporta y con que restricciones (showmount). Si un export no restringe por host o usuario, lo montas y navegas sus ficheros como si estuvieras en el servidor.

NFS confía en el UID/GID que le manda el CLIENTE para decidir permisos, en vez de autenticar de verdad; si tu Kali usa el mismo UID que el dueño de los ficheros en el servidor (o el export no restringe), lees y a veces escribes sin credenciales. Es la base también de nfs-no-root-squash, la variante que da privesc directo.

Modelo mental

Entrada controlada -> transformaciones -> validación -> componente final
-> sink -> efecto observable -> decisión

El paso crítico es demostrar qué componente consume el valor y con qué identidad o privilegios.

Superficie de ataque

Cuando el recon muestra el puerto 2049 (o 111 portmapper) abierto. Compruébalo siempre antes de intentar montar nada a ciegas.

Cómo identificarla

- Puerto 2049 (NFS) o 111 (portmapper) abierto en el escaneo.
- showmount -e devuelve al menos un export sin restricción de host.
- Al montar, los ficheros muestran UID/GID numéricos en vez de nombres (no coinciden con tus usuarios locales).

Preguntas que debo hacerme

- ¿Qué dato controlo exactamente y en qué formato viaja?
- ¿Qué transformaciones y normalizaciones ocurren antes del sink?
- ¿Qué identidad ejecuta la operación y qué permisos tiene?
- ¿Qué otra explicación produciría la misma señal?
- ¿Cuál es la prueba de menor riesgo que separa ambas explicaciones?

Prueba mínima

Pide la lista de exports con showmount -e contra la IP objetivo.

Evidencia esperada: Una lista de rutas exportadas (y sus restricciones de host, si las hay). Un export accesible para ti (* o tu rango) confirma que puedes montarlo.

Construcción progresiva del payload

1. Reproduce una entrada válida.
2. Aísla un único valor controlable.

3. Define la primitiva mínima indicada por la fuente.
4. Predice resultado y control negativo.
5. Aplica una sola adaptación cuando haya evidencia de restricción.
6. Confirma de forma reproducible antes de ampliar impacto.

Capa 1: prueba documentada

```
showmount -e $IP
```

Objetivo y contexto: Pregunta al servidor NFS que exporta y a quien, sin montar nada todavía. Es el primer paso obligado antes de montar a ciegas.

Resultado esperado: Rutas exportadas y su restricción de host (o * si es abierto a todos). Cada ruta accesible es un candidato a montar y explorar.

Capa 2: prueba documentada

```
sudo mount -t nfs $IP:/export /mnt/nfs
```

Objetivo y contexto: Monta el export localmente para navegarlo como un directorio normal. Requiere sudo porque montar sistemas de ficheros es una operación privilegiada en tu propia máquina.

Resultado esperado: El contenido del export disponible en /mnt/nfs. Explora en busca de ficheros de config, claves SSH, o binarios que puedas modificar.

Anatomía de los payloads

La primera prueba es `showmount -e $IP`. Separa sus delimitadores, operadores, opciones, operandos y variables; algunos elementos no estarán presentes según el contexto. Las comillas, barras y separadores pertenecen a una capa concreta. Usa la explicación de cada capa para determinar qué símbolo altera sintaxis y cuál transporta datos.

Variaciones según el contexto

No traslades una prueba entre sistemas operativos, motores, frameworks o versiones sin revisar sintaxis y comportamiento. Conserva la primitiva y vuelve a serializarla para el parser real.

Filtros y bypasses

No existe un bypass universal. Registra la forma enviada, la forma decodificada, la comparación, la normalización y la forma consumida. Una adaptación es válida solo si demuestra una discrepancia concreta; si la validación ocurre sobre la forma canónica y expresa la propiedad correcta, la variante no debe funcionar.

Evidencias de confirmación

Una lista de rutas exportadas (y sus restricciones de host, si las hay). Un export accesible para ti (* o tu rango) confirma que puedes montarlo.

Usa además una entrada inocua y un control negativo. No confundas reflexión, error genérico o demora aislada con confirmación.

Escalado de impacto

- Lista los exports disponibles con `showmount -e` antes de montar nada.
- Monta el export en un punto local y navega su contenido como cualquier directorio.
- Fijate en los UID/GID de los ficheros: si no coinciden con tu usuario, quizá necesites ajustar tu propio UID para leer/escribir como el dueño.
- Si el export tiene `no_root_squash`, no hace falta ajustar UID de lectura: puedes escalar directamente, ve a `nfs-no-root-squash`.

Amplía únicamente dentro del laboratorio y cuando cada salto aporte una capacidad nueva demostrable.

Errores frecuentes

- showmount -e no devuelve ningún export, o todos están restringidos a hosts que no eres tú.
- No tienes forma de montar NFS desde tu máquina de ataque.
- Ejecutar la prueba sin adaptar variables ni versión.
- Cambiar varias capas a la vez.
- Omitir el control negativo o no guardar evidencia.

Diagnóstico de payloads fallidos

Síntoma	Posible causa	Prueba de diagnóstico	Adaptación
Rechazo inmediato	Formato o precondition	Repetir entrada válida	Corregir transporte
Sin diferencia	Entrada ignorada o canal ciego	Marcador y control negativo	Buscar evidencia adecuada
Error del componente	Contexto o versión	Reducir a prueba mínima	Consultar manual detectado
Resultado parcial	Permisos/restricción	Comprobar identidad y alcance	Reducir primitiva

Mitigaciones

Eliminar el dato controlable del sink cuando sea posible; usar APIs estructuradas, allowlists sobre valores canónicos, privilegio mínimo, autorización en servidor y registros que permitan detectar abuso. La defensa concreta debe impedir la causa explicada en Fundamentos técnicos.

Relación con pentesting y certificaciones

Se espera reconocer la señal, justificar la prueba elegida, adaptar variables, interpretar salida y documentar impacto y mitigación. La puntuación debe premiar razonamiento y evidencia, no memoria literal.

Caso guiado

Parte de una señal de la lista anterior. Escribe observación e hipótesis, ejecuta la prueba mínima, compara con el control y clasifica el resultado como no confirmado, indicio o confirmación. Solo entonces sigue los pasos de escalado relevantes.

Caso de adaptación

Si la prueba básica falla, no cambies caracteres al azar. Comprueba primero transporte, parser, versión, permisos y canal de evidencia. Diseña una segunda prueba que discrimine entre las dos causas más probables.

Ejercicios

1. Señala source, transformaciones y sink en el caso guiado.
2. Explica qué evidencia refutaría la hipótesis.
3. Descompón la primera prueba documentada por opciones y argumentos.
4. Propón un control negativo y una mitigación causal.

Resumen

NFS lista que directorios exporta y a quien; montarlos revela ficheros del servidor directamente en tu Kali. La técnica queda confirmada solo cuando una prueba mínima produce la evidencia prevista y descarta explicaciones alternativas.

Chuleta operativa

1. Confirmar alcance y precondiciones.
2. Identificar entrada, componente y permisos.
3. Ejecutar prueba mínima y control.
4. Interpretar señal antes de escalar.
5. Guardar evidencia y mitigación.

Referencias

- [Concepto fuente de THM Fieldbook](#) (nfs - enum)
- [Referencia técnica externa](#)

Navegación

Anterior: [Construcción de payloads](#). Índice: [curso](#). Ejercicios y chuleta se enlazarán desde la matriz de trazabilidad.